AULA 2 – Introdução aos Conceitos de *Hash* e Criptografia

1. *Hash*: Garantindo a Integridade da Informação

Quando trabalhamos com segurança da informação, uma das primeiras propriedades que precisamos garantir é a **integridade dos dados**. Em termos simples, integridade significa ter condições de verificar se uma informação permanece exatamente como era originalmente ou se sofreu alguma alteração.

Imagine, por exemplo, que um arquivo chamado relatorio.pdf seja armazenado em um computador. Posteriormente, esse arquivo é copiado para outro dispositivo ou transmitido pela rede. Como podemos verificar se o arquivo recebido é exatamente o mesmo arquivo que foi originalmente produzido? Uma das técnicas utilizadas para essa finalidade é a **função *hash***.

1.1 O que é Função *Hash*

Uma função *hash* criptográfica é um algoritmo matemático que recebe uma entrada de tamanho variável — como um arquivo, uma mensagem ou qualquer sequência de dados — e produz como resultado uma sequência de tamanho fixo, denominada **valor *hash***, ***digest*** ou, de forma mais informal, "impressão digital" do dado. Podemos representar o processo da seguinte maneira:



Um arquivo de alguns *bytes* ou um arquivo de vários *gigabytes* pode ser submetido à mesma função *hash*. Independentemente do tamanho da entrada, o algoritmo produzirá uma saída de tamanho determinado (fixo).

No caso do **SHA-256**, por exemplo, o resultado possui **256 bits**, normalmente representados como uma sequência hexadecimal de **64 caracteres**. O valor *hash* não é uma cópia reduzida do arquivo. Ele é o resultado de uma *operação matemática* realizada sobre o conteúdo da entrada.

1.2 Por Que o *Hash* Pode Indicar uma Alteração

Uma propriedade importante das funções *hash* criptográficas é a chamada **sensibilidade à alteração da entrada**. Uma pequena modificação nos dados de entrada tende a produzir um valor *hash* completamente diferente. Considere, de forma simplificada:



Assim, ao comparar o valor *hash* conhecido de um arquivo com o valor *hash* calculado posteriormente sobre esse mesmo arquivo, podemos verificar sua **integridade.** É importante observar que o *hash* **não informa o que foi alterado**. Ele apenas permite identificar, por comparação, que os dados submetidos ao cálculo não produziram o mesmo resultado.

1.3 *Hash* não é Criptografia

Embora funções *hash* criptográficas utilizem princípios matemáticos relacionados à criptografia, ***hash* e criptografia não são a mesma coisa**. Essa distinção é fundamental. Na criptografia, o objetivo é transformar uma informação em um formato que não permita sua compreensão sem o conhecimento apropriado, possibilitando posteriormente a recuperação do conteúdo por meio da descriptografia. No *hash*, o objetivo é produzir um **resumo matemático do conteúdo**, utilizado, entre outras finalidades, para verificar sua integridade. Podemos resumir:

Mecanismo	Principal finalidade	Recuperação do conteúdo
Hash	Verificação de integridade	Não
Criptografia	Proteção da confidencialidade	Sim, mediante o mecanismo/chave apropriado

Portanto, não devemos dizer que um arquivo foi "criptografado" quando simplesmente calculamos seu *hash*, pois é dito que a *hash* é uma função só de ida, nunca de volta. Isto é, na prática não é possível reconstruir o conteúdo de um arquivo apenas por conhecer o seu valor *hash*.

1.4 O *Hash* na Segurança da Informação

A utilização de funções *hash* está presente em diversas aplicações de segurança da informação. Entre os exemplos estão:

- verificação da integridade de arquivos;
- armazenamento e verificação de senhas, mediante mecanismos apropriados de derivação de chaves;
- identificação de arquivos;
- verificação de downloads;
- assinaturas digitais;
- sistemas de controle de integridade;
- mecanismos de autenticação;
- Computação Forense e análise de evidências digitais.

Na Computação Forense, por exemplo, o *hash* possui papel particularmente importante porque permite verificar se determinado arquivo ou imagem forense permanece ***bit* a *bit* compatível** com o conteúdo utilizado como referência para o cálculo.

Uma maneira simples de compreender o conceito é imaginar que cada arquivo possui uma espécie de **impressão digital matemática**. Duas pessoas podem possuir arquivos visualmente semelhantes, mas uma alteração mínima no conteúdo pode resultar em impressões digitais diferentes.

Essa analogia, entretanto, possui uma limitação importante: uma impressão digital humana é uma característica física do indivíduo, enquanto o *hash* é um **valor matematicamente calculado a partir dos dados de entrada**.

Portanto, quando dizemos que o *hash* é a "impressão digital" de um arquivo, estamos utilizando uma analogia didática para facilitar a compreensão do conceito, uma vez que existem inúmeros algoritmos de extração de *hash*.

INSIGHT DO PROFESSOR

O hash não protege o conteúdo contra a leitura ou utilização. Ele permite verificar se o conteúdo apresentado é compatível com aquele que originou o valor *hash* de referência.



1.5 Principais Algoritmos *Hash*

Ao longo do desenvolvimento da computação, diversos algoritmos de *hash* foram criados e empregados em aplicações de segurança da informação. Entre os mais conhecidos estão o **MD5**, o **SHA-1** e os algoritmos pertencentes às famílias **SHA-2** e **SHA-3**. Esses algoritmos diferem principalmente em sua construção matemática, tamanho do valor hash produzido e resistência contra ataques criptográficos, especialmente os chamados **ataques de colisão**:

Algoritmo	Tamanho do hash	Representação hexadecimal	Situação atual
MD5	128 bits	32 caracteres	Criptograficamente inseguro
SHA-1	160 bits	40 caracteres	Criptograficamente inseguro
SHA-256	256 bits	64 caracteres	Seguro para uso atual
SHA-512	512 bits	128 caracteres	Seguro para uso atual
SHA3-256	256 bits	64 caracteres	Seguro para uso atual
SHA3-512	512 bits	128 caracteres	Seguro para uso atual

Portanto, uma característica fundamental das funções *hash* é a possibilidade de **verificação da integridade da informação**. E é justamente essa diferença que nos permitirá avançar para o próximo conceito: enquanto o *hash* está relacionado principalmente à **integridade**, a criptografia será utilizada para tratar de outra propriedade fundamental da Segurança da Informação: a **confidencialidade**.

2. Criptografia

Na seção anterior, vimos que as funções *hash* podem ser utilizadas para verificar a **integridade** de uma informação. Agora, vamos abordar outra propriedade fundamental da Segurança da Informação: a **confidencialidade**. Confidencialidade significa garantir que uma informação somente possa ser acessada ou compreendida por pessoas, sistemas ou entidades devidamente autorizadas. Uma das principais tecnologias utilizadas para alcançar esse objetivo é a **criptografia**.

2.1 Conceito de Criptografia

A criptografia é o conjunto de técnicas e algoritmos utilizados para transformar uma informação legível em uma representação que não possa ser compreendida diretamente por pessoas ou sistemas que não possuam os elementos necessários para sua recuperação. A informação original é submetida a um algoritmo criptográfico juntamente com uma **chave criptográfica**, produzindo como resultado uma informação cifrada. De forma simplificada:



O objetivo da criptografia não é simplesmente "esconder" uma informação. Seu propósito é utilizar **mecanismos matemáticos e chaves criptográficas** para tornar computacionalmente inviável que um terceiro não autorizado obtenha o conteúdo original. É importante destacar que criptografia e codificação são conceitos diferentes.

Uma informação codificada pode, em muitos casos, ser simplesmente convertida de uma representação para outra. A criptografia, por outro lado, utiliza mecanismos destinados a fornecer **propriedades de segurança**, especialmente a **confidencialidade**.

2.2 Texto claro e texto cifrado

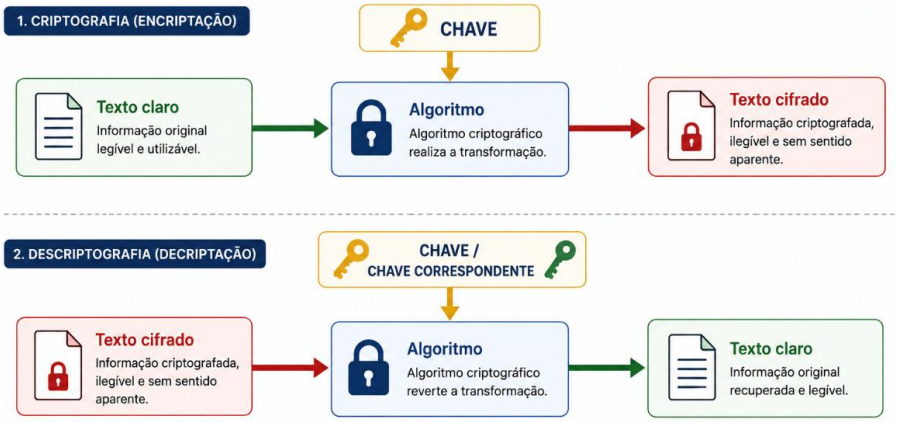
Para compreender o funcionamento da criptografia, precisamos conhecer dois conceitos fundamentais. O primeiro é o **texto claro** (*plaintext*) é a informação em sua forma original, antes da aplicação do processo de criptografia.



Depois da aplicação do algoritmo criptográfico, temos o **texto cifrado** (*ciphertext*). O resultado não precisa possuir qualquer relação visual com a informação original. Apenas possuir o texto cifrado não deve permitir que um atacante consiga obter o texto claro de maneira prática, desde que o algoritmo e o gerenciamento das chaves sejam adequados.

2.3 O papel da chave criptográfica

Um dos elementos mais importantes da criptografia é a **chave criptográfica**. A chave pode ser entendida, de maneira simplificada, como uma informação utilizada pelo algoritmo para controlar o processo de transformação entre texto claro e texto cifrado. Podemos representar:



É importante não confundir **algoritmo criptográfico** com **chave criptográfica**. O algoritmo define o conjunto de operações matemáticas utilizadas no processo. A chave é um valor que participa desse processo e que, dependendo do sistema criptográfico empregado, pode ser secreta ou pública.

Essa distinção é fundamental porque, em sistemas criptográficos modernos, a segurança não deve depender do segredo do algoritmo. Em outras palavras: **O algoritmo pode ser conhecido publicamente; o elemento que precisa ser protegido é a chave.** Essa ideia é um dos princípios fundamentais da criptografia moderna.

2.4 Criptografia simétrica

Na **criptografia simétrica**, utiliza-se a mesma chave secreta — ou chaves diretamente relacionadas — para realizar a cifragem e a posterior recuperação da informação. De forma simplificada:



Imagine que Alice deseja enviar uma informação confidencial para Bob. Antes que Bob possa descriptografar a mensagem, ambos precisam possuir a chave secreta adequada. O problema fundamental passa a ser: **Como Alice entrega a chave secreta a Bob de maneira segura?** Esse é conhecido como **problema da distribuição de chaves**.

Apesar dessa dificuldade, a criptografia simétrica possui uma importante vantagem: normalmente apresenta **alto desempenho**, sendo adequada para proteger grandes volumes de dados. Entre os algoritmos simétricos conhecidos estão:

- **AES (Advanced Encryption Standard)**;
- **ChaCha20**;
- **3DES**, atualmente considerado legado e inadequado para novos projetos.

O **AES**, em particular, é amplamente utilizado em sistemas modernos de segurança da informação. Como exemplo de utilização, a criptografia simétrica pode ser utilizada para proteger:

- discos e volumes;
- bancos de dados;
- grandes volumes de dados em trânsito;
- backups;
- comunicações protegidas.

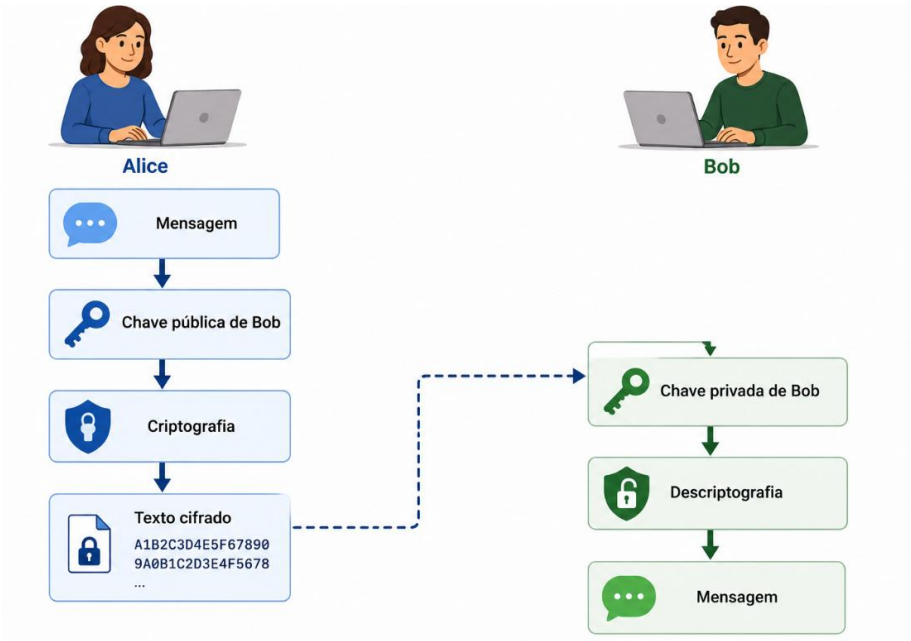
Por exemplo, quando um disco é criptografado, os dados armazenados podem permanecer em uma forma que não seja diretamente compreensível para alguém que obtenha acesso físico ao dispositivo sem possuir as credenciais ou chaves necessárias.

2.5 Criptografia assimétrica

A **criptografia assimétrica**, também denominada **criptografia de chave pública**, utiliza um par de chaves matematicamente relacionadas:

- **chave pública**;
- **chave privada**.

A chave pública pode ser distribuída livremente, enquanto a chave privada deve ser mantida sob controle de seu proprietário. Uma das aplicações clássicas consiste em utilizar a chave pública de Bob para proteger uma informação que somente Bob poderá recuperar utilizando sua chave privada correspondente.



A principal vantagem é que Alice não precisa receber previamente uma chave secreta compartilhada com Bob. Entretanto, algoritmos assimétricos geralmente apresentam desempenho inferior aos algoritmos simétricos para a proteção de grandes quantidades de dados. Entre os algoritmos e sistemas associados à criptografia assimétrica estão:

- **RSA**;
- **ECC (Elliptic Curve Cryptography)**;

- **ECDH**, utilizado para estabelecimento de chaves;
- **EdDSA**, utilizado em assinaturas digitais.

É importante observar que nem todos esses mecanismos possuem exatamente a mesma finalidade. Alguns são utilizados para criptografia, outros para **acordo de chaves** ou **assinaturas digitais**.

2.6 Exemplos de utilização da criptografia

A criptografia está presente em praticamente todos os ambientes modernos de tecnologia da informação. Alguns exemplos incluem:

- **Comunicações pela Internet:** Protocolos como **TLS (Transport Layer Security)** utilizam mecanismos criptográficos para proteger comunicações entre clientes e servidores. É o que está por trás, por exemplo, das conexões HTTPS utilizadas pelos navegadores.



- **Redes sem fio:** as redes Wi-Fi modernas utilizam mecanismos criptográficos para impedir que qualquer pessoa dentro do alcance do sinal consiga simplesmente interpretar o tráfego protegido. Tecnologias como **WPA2** e **WPA3** utilizam mecanismos criptográficos para proteger as comunicações da rede sem fio.

- **Armazenamento de dados:** A criptografia pode ser utilizada para proteger:
  - discos rígidos;
  - SSDs;
  - dispositivos móveis;
  - arquivos;
  - bancos de dados;
  - backups.

Nesse cenário, mesmo que alguém obtenha acesso físico ao dispositivo, os dados podem permanecer inacessíveis sem os mecanismos de autenticação e as chaves apropriadas.

- **Mensagens e comunicações:** aplicações de comunicação podem utilizar criptografia para proteger mensagens durante sua transmissão. Um exemplo do uso é o *Whatsapp*.
- **Assinaturas digitais:** a criptografia assimétrica também desempenha papel importante nas **assinaturas digitais**. Nesse caso, o objetivo não é simplesmente manter uma mensagem secreta. A assinatura digital pode fornecer propriedades como: autenticidade; integridade; e não repúdio, dentro do modelo jurídico e técnico aplicável.

3. RANSOMWARE — O USO MALICIOSO DA CRIPTOGRAFIA

A criptografia é uma tecnologia legítima utilizada para proteger informações. Entretanto, seus mecanismos também podem ser empregados por agentes maliciosos. O ***ransomware*** é um dos principais exemplos: trata-se de um tipo de *malware* que utiliza técnicas de criptografia para tornar os arquivos da vítima inacessíveis, normalmente com o objetivo de exigir um resgate.

3.1 Como o *ransomware* utiliza a criptografia

O *ransomware* pode utilizar **criptografia simétrica** para cifrar rapidamente grandes quantidades de arquivos e **criptografia assimétrica** para proteger a chave utilizada nesse processo. **Por que a vítima não consegue simplesmente descriptografar os arquivos?** Conhecer o algoritmo utilizado não é suficiente para recuperar os dados. É necessário possuir a **chave criptográfica correspondente**.

Quando a criptografia é adequadamente implementada e utiliza chaves suficientemente robustas, tentar descobri-las por força bruta pode ser computacionalmente inviável. Por isso, simplesmente renomear os arquivos ou alterar suas extensões não recupera o conteúdo original. A recuperação depende da existência de uma chave válida, de uma ferramenta de descriptografia compatível, de alguma vulnerabilidade na implementação do *ransomware* ou, principalmente, de **backups íntegros**.



3.2 Como acontece a contaminação por *Ransomware*

Uma das formas frequentemente utilizadas para iniciar uma infecção por *ransomware* é o **phishing**. Nesse tipo de ataque, o criminoso utiliza mensagens, e-mails ou páginas falsas para induzir a vítima a realizar uma ação, como abrir um arquivo malicioso, executar um programa ou acessar um endereço fraudulento.

É importante destacar que o *phishing* não é o *ransomware* propriamente dito. O *phishing* pode funcionar como **vetor de acesso inicial**, enquanto o *ransomware* é o código malicioso que posteriormente compromete os dados.

Após obter execução no sistema, o *ransomware* pode procurar arquivos e recursos acessíveis à vítima ou ao sistema comprometido. Em seguida, pode gerar uma **chave de sessão**, utilizada para realizar a criptografia dos arquivos.

A chave de sessão pode ser posteriormente protegida por mecanismos de criptografia assimétrica, dificultando sua recuperação por terceiros. Como consequência, os arquivos tornam-se inacessíveis aos usuários, e o atacante apresenta uma **nota de resgate**, geralmente exigindo algum tipo de pagamento em troca da suposta recuperação dos dados.



3.3 Defesa contra *ransomware*

A proteção deve utilizar uma estratégia de **defesa em profundidade**, combinando diferentes controles:

- **Backup:** manter cópias protegidas e testar regularmente sua restauração.
- **Controle de acesso:** aplicar o princípio do menor privilégio.
- **Segmentação de redes:** limitar a propagação do ataque.
- **MFA:** adicionar uma camada adicional de proteção às credenciais.
- **Atualizações:** corrigir vulnerabilidades conhecidas.
- **EDR/antimalware:** detectar arquivos e comportamentos suspeitos.
- **Monitoramento:** identificar alterações anormais, como modificações massivas de arquivos.
- **Plano de resposta a incidentes:** definir procedimentos para contenção, investigação e recuperação.

Nenhuma dessas medidas, isoladamente, elimina o risco. A segurança depende da combinação de **prevenção, detecção, contenção e capacidade de recuperação**. **A criptografia protege a informação quando utilizada corretamente. No *ransomware*, a mesma tecnologia é utilizada para retirar da vítima o controle sobre seus próprios dados.**

3.4 Atividade Utilizando os Conceitos de *Ransomware*

Exercício em sala de aula consiste em simular, de forma controlada e exclusivamente para fins didáticos, um ataque de criptografia de arquivos inspirado no funcionamento do **WannaCry**, um dos mais conhecidos ataques de *ransomware* da história.

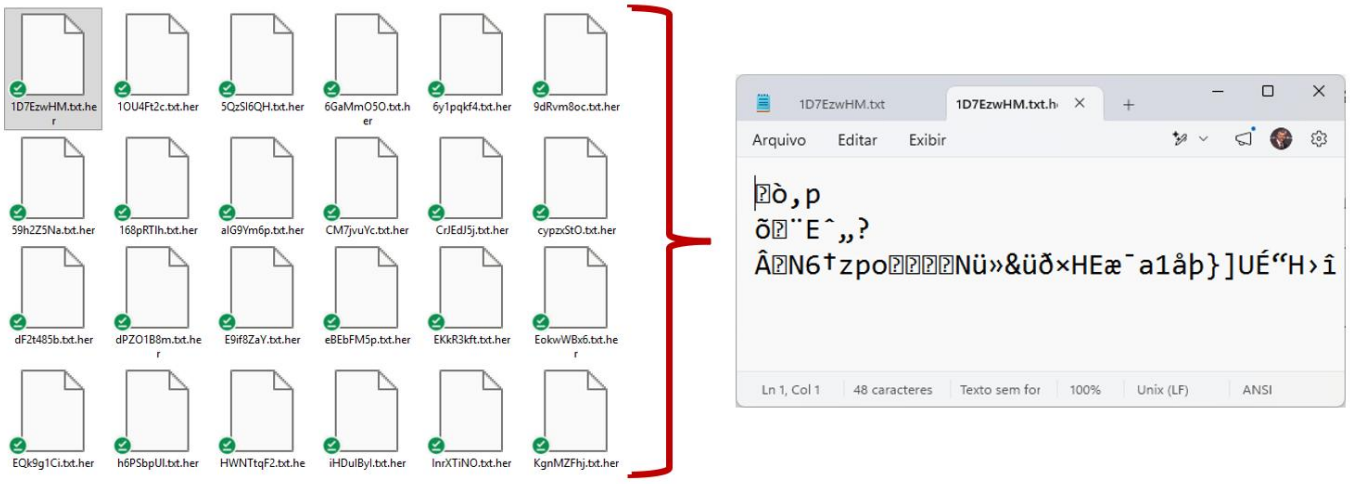
O *malware*, identificado em 2017, combinava a criptografia de arquivos com mecanismos de propagação automática entre sistemas vulneráveis, contribuindo para a rápida disseminação do ataque em escala global. O exercício busca demonstrar, de maneira segura, o processo de identificação dos arquivos, geração de uma chave de sessão, criptografia, proteção da chave e consequente indisponibilidade dos dados, sem utilizar código malicioso real.

Para o nosso exercício, foram gerados vários arquivos no formato txt com nomes e textos aleatórios, conforme ilustrado pela imagem abaixo:



Após a infecção do *ramsonware*, os arquivos passam a ter outra extensão “her” diferente a extensão padrão “txt”. Assim, todos os documentos passam a apresentar uma extensão adicional, como .txt.her, indicando que foram processados pelo *ransomware*.

Como não bastasse a troca da extensão padrão, o que muitos usuários instintivamente retornariam à extensão padrão “txt’, o ramsonware tamvém criptografa o conteúdo interno do arquivo tornando **ilegível.** Ao tentar abrir um dos arquivos, o conteúdo aparece como uma sequência de caracteres sem significado aparente. Isso demonstra que o arquivo continua existindo, mas seus dados foram transformados pelo processo criptográfico e **não podem mais ser interpretados normalmente**.



A dinâmica da atividade consiste em utilizar um "simulador" de pedido de resgate para decriptar os arquivos comprometidos através de uma "semente", isto é, uma chave ou senha fornecida pelo *cracker*:



A atividade possibilitou demonstrar, de forma controlada e didática, os principais efeitos decorrentes de um ataque de *ransomware*, estabelecendo uma relação entre os fundamentos teóricos da criptografia e sua utilização em um cenário de comprometimento da disponibilidade dos dados. A alteração dos arquivos e a consequente impossibilidade de interpretação de seu conteúdo evidenciam os efeitos do processo de cifragem aplicado de forma maliciosa.

EXERCÍCIOS



As atividades propostas durante e ao final das aulas têm como objetivo reforçar os conceitos apresentados e estimular a reflexão contínua. Não deixe de fazer ou revisar os exercícios.

1. Sobre as funções hash, assinale a alternativa correta:

a) Uma função hash permite recuperar o conteúdo original do arquivo a partir do valor hash.

b) Uma função hash transforma uma entrada de tamanho fixo em uma saída de tamanho variável.

c) Uma função hash é utilizada exclusivamente para criptografar arquivos.

d) **Uma função hash recebe uma entrada de tamanho variável e produz um valor de tamanho fixo, utilizado, entre outras finalidades, para verificar a integridade dos dados.**

---

2. Em relação ao SHA-256, é correto afirmar que:

a) Produz um valor de 128 bits, normalmente representado por 32 caracteres hexadecimais.

b) **Produz um valor de 256 bits, normalmente representado por 64 caracteres hexadecimais.**

c) Produz um valor de 512 bits, normalmente representado por 256 caracteres hexadecimais.

d) Permite recuperar o conteúdo original do arquivo utilizando o valor hash.

---

3. Qual das alternativas apresenta corretamente a principal diferença entre hash e criptografia?

a) Hash é utilizado para confidencialidade, enquanto criptografia é utilizada exclusivamente para integridade.

b) Ambos são processos reversíveis, desde que seja conhecida a chave correta.

c) **Hash é utilizado, entre outras finalidades, para verificar a integridade, enquanto a criptografia pode ser utilizada para proteger a confidencialidade das informações.**

d) Hash e criptografia são denominações diferentes para o mesmo mecanismo matemático.

---

4. Na criptografia simétrica:

a) **É utilizada uma chave secreta para realizar a cifragem e a posterior recuperação da informação.**

b) São utilizadas obrigatoriamente duas chaves públicas.

c) A chave privada pode ser divulgada livremente.

d) O algoritmo utilizado deve permanecer secreto para garantir a segurança do sistema.

---

5. Sobre a criptografia assimétrica, assinale a alternativa correta:

a) Utiliza somente uma chave secreta compartilhada entre remetente e destinatário.

b) É utilizada exclusivamente para criptografar discos rígidos.

c) Apresenta desempenho superior à criptografia simétrica na proteção de grandes volumes de dados.

d) **Utiliza um par de chaves matematicamente relacionadas: uma chave pública e uma chave privada.**

---

6. Qual das alternativas apresenta um exemplo correto de utilização da criptografia na Segurança da Informação?

a) **Proteção de comunicações por meio de protocolos como TLS e proteção de dados armazenados.**

b) Geração de valores hash exclusivamente para identificação de arquivos.

c) Substituição do endereço IP de um computador por um endereço MAC.

d) Exclusão automática de arquivos considerados suspeitos pelo sistema operacional.

---

7. No contexto de um ataque de ransomware, qual é a função da chave de sessão?

a) Identificar o computador da vítima na rede.

b) Permitir que o usuário altere a extensão dos arquivos criptografados.

c) **Ser utilizada para realizar a criptografia dos arquivos, podendo posteriormente ser protegida por mecanismos de criptografia assimétrica.**

d) Substituir o sistema operacional da vítima após a infecção.

8. Sobre phishing e ransomware, assinale a alternativa correta:

a) Phishing e ransomware são exatamente o mesmo tipo de malware.

b) O ransomware é utilizado exclusivamente para enviar mensagens fraudulentas.

c) O phishing ocorre somente depois que os arquivos da vítima já foram criptografados.

d) **O phishing pode funcionar como vetor de acesso inicial, induzindo a vítima a executar uma ação que possibilite a infecção pelo ransomware.**

---

9. Qual das alternativas apresenta corretamente uma sequência conceitual de funcionamento de um ransomware?

a) Criptografia → infecção → exclusão dos arquivos → geração da chave → nota de resgate.

b) **Infecção → identificação dos arquivos → geração da chave de sessão → criptografia → proteção da chave → arquivos inacessíveis → nota de resgate.**

c) Infecção → descriptografia → identificação dos arquivos → recuperação da chave → nota de resgate.

d) Identificação dos arquivos → backup → descriptografia → geração da chave → recuperação dos dados.

---

10. Sobre a defesa contra ransomware, assinale a alternativa correta:

a) A utilização de um único software antimalware elimina o risco de ransomware.

b) Alterar regularmente a extensão dos arquivos impede a ação do ransomware.

c) **A proteção deve utilizar uma estratégia de defesa em profundidade, combinando medidas como backup, controle de acesso, segmentação de redes, MFA, atualizações, EDR/antimalware, monitoramento e plano de resposta a incidentes.**

d) A principal medida de segurança consiste em manter todos os usuários com privilégios administrativos.